

概要设计说明书

项目名称：在线 OJ 在线判题系统

版本：V2026.07

成员：	<u>42411167 陆思雨</u>
成员：	<u>42411107 钟晶卉</u>
成员：	<u>42436015 刘洛嘉</u>
成员：	<u>42311115 郑羽婷</u>
成员：	<u>42405057 杨凯悦</u>
成员：	<u>42411052 乔鑫钰</u>

目录

目录	1
1 引言	4
1.1 编写目的	4
1.2 项目背景	4
1.3 定义	4
1.4 参考资料	4
2 任务概述	5
2.1 目标	5
2.2 运行环境	5
2.3 需求概述	5
2.4 条件与限制	5
3 总体设计	6
3.1 处理流程	6
3.2 总体结构和模块外部设计	6
3.3 功能分配	6
4 接口设计	6
4.1 接口架构与设计原则	6
4.2 用户界面接口	7
4.2.1 管理员界面	8
4.2.2 学生界面	8
4.2.3 教师界面	8
4.3 外部软件接口	8
4.4 内部模块接口	8
4.5 异步任务接口	9
4.6 通用接口约定	9
5 数据结构设计	10
5.1 数据架构原则	10
5.2 逻辑结构设计	10
5.2.1 组织与身份数据	10
5.2.2 模板数据	10
5.2.3 写作与引用数据	10
5.2.4 导出与批阅数据	11
5.3 核心实体关系	11
5.4 状态模型与一致性约束	11
5.4.1 模板状态	11
5.4.2 论文状态	11
5.4.3 并发与版本约束	12

5.5	物理结构设计	12
5.6	索引与查询策略	12
5.7	数据结构与模块关系	12
6	运行设计	13
6.1	部署与进程结构	13
6.2	运行模块组合	13
6.3	关键运行流程	14
6.3.1	论文自动保存流程	14
6.3.2	预览与导出流程	14
6.3.3	提交与批阅流程	14
6.4	运行控制	14
6.5	性能与容量设计	15
6.6	定时任务	15
7	出错处理设计	15
7.1	处理原则与异常分类	15
7.2	出错输出信息	16
7.3	主要异常及处理对策	16
7.4	重试、补偿与回滚	16
7.5	日志、监控与告警	17
8	安全保密设计	17
8.1	安全目标与信任边界	17
8.2	身份认证与权限控制	17
8.3	接口与会话安全	17
8.4	富文本与文件安全	18
8.5	数据保护与保密	18
8.6	审计与安全事件	18
9	维护设计	19
9.1	维护目标与总体策略	19
9.2	模块与依赖维护	19
9.3	配置与版本管理	19
9.4	日志与监控维护	19
9.5	数据备份与恢复	20
9.6	发布、回滚与兼容性维护	20
9.7	例行维护计划	20
9.8	扩展与演进设计	20

版本修订记录

版本	日期	修改人	审核	修改说明
V1.0	2026-07-11	张三	李四	初稿完成，完成系统总体架构、模块、接口、数据结构概要设计梳理
V1.1	2026-07-12	张三	王五	补充判题流程、异常出错处理、安全与维护相关设计内容

1 引言

1.1 编写目的

本文档为在线 OJ 在线判题系统概要设计说明书，基于前期软件需求规格说明书完成系统顶层架构设计。文档用于明确系统整体模块划分、业务处理流程、内外接口规范、数据库数据结构、运行控制方案、异常处理、安全及维护设计，为后续详细设计、编码开发、单元测试提供设计依据。

本文档阅读对象包含项目负责人、系统架构设计师、前后端开发工程师、测试工程师。

1.2 项目背景

本系统为高校大二软件工程实训开发项目，开发主体为校内实训开发小组，服务于高校程序设计课程教师与在校学生。系统独立部署，无第三方业务系统对接，依靠 Web 服务、判题沙箱服务、关系型数据库实现完整在线编程、自动评测、教学管理业务闭环，用于支撑线上编程练习、作业自动批改、学情数据统计。

当前高校程序设计课程教学中，教师布置编程作业后需要人工逐一查看学生代码并手动运行测试，效率低下且难以保证评测标准的一致性。本系统通过自动化判题机制，能够大幅减轻教师批改负担，同时为学生提供即时反馈，提升学习效率。

1.3 定义

- OJ: Online Judge, 在线程序自动判题系统;
- AC: Accepted, 代码通过全部测试用例; item PE: Presentation Error, 输出格式错误;
- WA: Wrong Answer, 答案错误;
- TLE: Time Limit Exceeded, 运行超时;
- MLE: Memory Limit Exceeded, 内存超限;
- RE: Runtime Error, 运行时错误;
- CE: Compile Error, 编译错误;
- 判题沙箱: 隔离执行用户代码的安全运行环境, 限制资源访问, 防范恶意代码破坏服务;
- 测试用例: 包含标准输入、预期输出、边界条件的程序评测数据集;
- 判题任务队列: 缓存待执行判题任务的异步调度队列;
- RESTful API: 前后端交互标准接口规范。

1.4 参考资料

1. GB/T 9386-2008 计算机软件概要设计说明书规范；
2. 《在线 OJ 在线判题系统软件需求规格说明书》V2026.07；
3. 2026 软件工程实训项目任务书；
4. Web 前后端分离开发设计规范；
5. Linux 沙箱安全隔离开发技术文档；
6. MySQL 数据库设计开发规范。

2 任务概述

2.1 目标

搭建一套前后端分离架构的在线编程自动判题平台，划分学生、教师两类角色；拆解系统为用户模块、题库模块、在线代码编辑与判题模块、提交记录统计模块、讨论区模块、系统监控管理模块；实现题库分级管理、在线代码提交、沙箱自动编译评测、刷题数据排行、师生交流讨论、教师后台运维监控全套能力，满足高校编程课程线上练习、自动批改、学情统计教学需求。

2.2 运行环境

- 服务端操作系统：Linux CentOS 7 / Windows Server 2019；
- Web 服务容器：Nginx、Tomcat；
- 数据库：MySQL 8.0；
- 判题依赖：GCC、Python、Java 等多语言编译器、进程隔离沙箱程序；
- 客户端环境：Chrome、Edge、Firefox 主流现代浏览器；
- 中间件：Redis（缓存、任务队列）。

2.3 需求概述

系统分为学生端与教师管理端两大业务域：

1. 学生端：账号注册登录、分级题库浏览、在线代码编写提交、自动判题结果反馈、个人提交记录与刷题统计、全站排行榜、题目讨论区发帖交流；
2. 教师端：题库增删改查、批量导入题目、测试用例配置、全量用户与提交行为监管、异常抄袭提交标记、平台运行状态可视化监控、公告发布、讨论区内容审核管理、教学统计报表导出。

2.4 条件与限制

1. 判题模块必须采用沙箱隔离机制，禁止用户代码直接读写服务器文件、访问网络；
2. 单份代码运行设置时间、内存双重上限，防止服务器资源耗尽；
3. 系统仅开放学生、教师两类角色，无游客完整答题权限；
4. 题库批量导入仅支持标准结构化文本文件，不支持自定义复杂格式；
5. 服务器硬件资源有限，并发判题任务存在最大并发阈值；
6. 所有接口需携带身份鉴权凭证，严格区分角色数据访问权限。

3 总体设计

3.1 处理流程

1. 用户注册/登录鉴权，校验身份后跳转对应功能页面；
2. 学生浏览题库，选定题目进入在线代码编辑器，编写代码提交至后端；
3. 后端接收代码、题目 ID，封装判题任务送入 Redis 任务队列；
4. 判题服务消费队列任务，调度沙箱隔离运行代码，加载对应测试用例逐组比对输出；
5. 收集判题状态、运行耗时、内存占用结果，写入数据库提交记录；
6. 前端轮询获取判题结果，展示评测状态、错误日志；
7. 系统同步更新个人解题统计、全站排行榜数据；
8. 教师登录后台，完成题库维护、用户监管、平台监控、讨论区管理操作；
9. 所有操作行为记录系统日志，异常数据触发预警提示。

3.2 总体结构和模块外部设计

系统整体采用分层架构，自上而下分为四层：前端展示层、应用服务层、判题服务层、数据持久层，拆分六大独立业务模块：

1. 用户权限模块：账号注册登录、身份鉴权、角色权限控制、个人信息管理；
2. 题库管理模块：题目 CRUD、难度标签管理、测试用例配置、批量导入导出；
3. 在线判题模块：在线代码编辑器、任务队列调度、沙箱编译运行、结果判定；
4. 数据统计排行模块：个人提交记录、解题统计、全站实时排行榜、教学报表；
5. 讨论与公告模块：题目讨论帖子、评论回复、全站公告发布、内容审核；
6. 系统运维监控模块：在线人数、判题队列、编译器负载、服务器健康监控、异常提交标记。

3.3 功能分配

- 用户权限模块：承担登录校验、账号管理、接口鉴权全部功能；
- 题库管理模块：负责题目基础数据、测试用例、难度分类的存储与维护；
- 在线判题模块：承载代码接收、异步调度、沙箱执行、结果比对核心逻辑；
- 数据统计排行模块：读取提交记录，实时计算通过率、解题数量、排名数据；
- 讨论与公告模块：管理帖子、评论、公告内容及教师审核操作；
- 系统运维监控模块：采集服务器与业务运行指标，提供可视化监控视图与违规标记功能。

4 数据结构设计

4.1 数据库逻辑结构

系统采用 MySQL 8.0 关系型数据库，核心数据表设计如下：

4.1.1 用户相关表

- 用户表 (**sys_user**)：存储用户 ID、用户名、加密密码、邮箱、角色类型（学生/教师）、注册时间、最后登录时间、账号状态（正常/禁用）等字段。用户 ID 为主键，用户名为唯一索引。
- 用户扩展信息表 (**sys_user_profile**)：存储用户昵称、学校、年级、真实姓名、学号/工号等扩展属性，与用户表通过用户 ID 外键关联。

4.1.2 题库相关表

- 题目表 (**problem**)：存储题目 ID、标题、题目描述（富文本）、输入描述、输出描述、样例输入、样例输出、提示信息、难度等级（简单/中等/困难）、时间限制（秒）、内存限制（MB）、通过次数、提交次数、创建教师 ID、创建时间、更新时间、是否启用等字段。
- 测试用例表 (**test_case**)：存储用例 ID、所属题目 ID、输入数据、期望输出、是否为样例用例、权重分数等字段。一个题目可关联多个测试用例。
- 标签表 (**tag**)：存储标签 ID、标签名称、标签颜色等字段，用于题目分类管理。
- 题目标签关联表 (**problem_tag**)：维护题目与标签的多对多关联关系。

4.1.3 判题相关表

- 提交记录表 (**submission**)：存储提交 ID、题目 ID、用户 ID、提交代码内容、编程语言（C/C++/Java/Python 等）、判题状态（待判题/判题中/AC/WA/TLE/MLE/RE/CE/PE）、运行耗时（毫秒）、内存消耗（KB）、提交时间、判题完成时间等字段。

- **判题详情表 (submission_detail)**: 存储每次提交的详细判题结果, 包含每个测试用例的执行结果、实际输出、期望输出、运行耗时、内存消耗等详细数据, 用于调试和错误分析。

4.1.4 统计排行相关表

- **每日解题统计表 (daily_stats)**: 存储用户 ID、统计日期、当日解题数、当日提交数、连续打卡天数等数据, 用于生成学习趋势图表。
- **排行榜快照表 (rank_snapshot)**: 周期性存储全站用户排名数据, 包含用户 ID、总解题数、总提交数、通过率、综合评分、排名等字段, 用于历史排名追溯。

4.1.5 讨论区相关表

- **帖子表 (post)**: 存储帖子 ID、标题、内容、发帖用户 ID、所属题目 ID (可为空)、置顶标记、精华标记、审核状态、浏览次数、回复数量、创建时间、更新时间。
- **评论表 (comment)**: 存储评论 ID、内容、评论用户 ID、所属帖子 ID、父评论 ID (支持多级嵌套)、创建时间、点赞数等字段。

4.1.6 系统监控相关表

- **系统日志表 (sys_log)**: 存储日志 ID、操作人 ID、操作类型、操作内容、IP 地址、User-Agent、请求 URL、请求参数、操作时间等字段, 用于审计追溯。
- **系统指标表 (sys_metric)**: 存储指标 ID、指标名称 (在线人数/队列长度/CPU 使用率/内存使用率等)、指标值、采集时间等字段, 用于监控大屏展示。

4.2 数据物理存储设计

- InnoDB 存储引擎, 支持事务与行级锁;
- 用户表、提交记录表采用自增 BIGINT 主键, 按时间维度进行分区;
- 提交记录表中的代码内容字段采用 MEDIUMTEXT 类型, 最大存储 16MB;
- 测试用例表中的输入输出字段采用 TEXT 类型;
- 为常用查询字段 (用户 ID、题目 ID、提交时间、判题状态) 建立普通索引;
- 唯一索引: 用户名、邮箱;
- 外键约束在逻辑层维护, 物理层避免过多外键影响写入性能;
- 配置每日凌晨自动备份, 备份数据保留 30 天。

4.3 缓存设计

- 使用 Redis 作为缓存层，缓存热点数据：
- 题目详情缓存：key 为 problem:{problemId}，过期时间 1 小时；
- 排行榜数据缓存：key 为 rank:global，过期时间 5 分钟；
- 用户会话缓存：key 为 session:{userId}，过期时间 30 分钟；
- 判题任务队列：使用 Redis List 结构存储待判题任务；
- 分布式锁：使用 Redisson 实现判题服务分布式锁，防止任务重复消费。

5 接口设计

5.1 内部接口规范

系统采用前后端分离架构，所有接口遵循 RESTful 设计规范。接口路径以 /api 开头，版本号以 /v1 标识。请求与响应统一采用 JSON 格式，字符编码 UTF-8。

5.1.1 统一响应格式

```
{
  "code": 200,           // 状态码，200表示成功，其他表示失败
  "message": "success", // 响应消息
  "data": {},           // 响应数据
  "timestamp": 1699000000000 // 时间戳
}
```

5.1.2 用户模块接口

- POST /api/v1/auth/register: 用户注册，请求体包含用户名、密码、邮箱、角色类型；
- POST /api/v1/auth/login: 用户登录，请求体包含用户名、密码，响应返回 JWT Token 与用户基本信息；
- POST /api/v1/auth/logout: 用户登出，携带 Token 访问，后端将 Token 加入黑名单；
- GET /api/v1/user/profile: 获取当前用户个人信息；
- PUT /api/v1/user/profile: 修改个人信息；
- PUT /api/v1/user/password: 修改密码，需验证旧密码。

5.1.3 题库模块接口

- GET /api/v1/problems: 分页获取题目列表, 支持按难度、标签、关键词筛选;
- GET /api/v1/problems/{id}: 获取题目详情 (含样例输入输出);
- POST /api/v1/problems (教师): 创建题目;
- PUT /api/v1/problems/{id} (教师): 修改题目;
- DELETE /api/v1/problems/{id} (教师): 删除题目;
- POST /api/v1/problems/import (教师): 批量导入题目 (文件上传);
- GET /api/v1/tags: 获取所有标签列表。

5.1.4 判题模块接口

- POST /api/v1/submissions: 提交代码判题, 请求体包含题目 ID、代码内容、编程语言;
- GET /api/v1/submissions/{id}: 查询提交状态与判题结果;
- GET /api/v1/submissions: 分页获取当前用户的提交历史;
- GET /api/v1/submissions/{id}/detail: 获取某次提交的详细判题结果 (各测试用例执行情况);
- GET /api/v1/submissions/problem/{problemId}: 获取某道题目的所有提交记录 (学生查看个人, 教师查看全部)。

5.1.5 排行统计接口

- GET /api/v1/rank/global: 获取全站排行榜, 支持按解题数、通过率排序;
- GET /api/v1/user/stats: 获取当前用户的解题统计 (总提交、总通过、通过率、各难度解题分布);
- GET /api/v1/user/stats/{userId}: 获取指定用户的解题统计 (教师权限);
- GET /api/v1/admin/report (教师): 获取教学统计报表 (班级整体通过率、平均提交次数等)。

5.1.6 讨论区接口

- GET /api/v1/posts: 获取帖子列表, 支持按题目筛选;
- POST /api/v1/posts: 发帖;
- GET /api/v1/posts/{id}: 获取帖子详情 (含评论列表);

- PUT /api/v1/posts/{id}: 编辑帖子;
- DELETE /api/v1/posts/{id}: 删除帖子;
- POST /api/v1/posts/{id}/comments: 发表评论;
- DELETE /api/v1/comments/{id}: 删除评论;
- PUT /api/v1/posts/{id}/status (教师): 审核帖子 (通过/驳回/置顶/加精)。

5.1.7 监控管理接口

- GET /api/v1/admin/metrics (教师): 获取系统实时监控指标 (在线人数、队列长度、CPU/内存使用率);
- GET /api/v1/admin/submissions (教师): 获取全站提交记录, 支持按用户、题目、状态筛选;
- POST /api/v1/admin/submissions/{id}/flag (教师): 标记异常提交 (抄袭嫌疑);
- POST /api/v1/admin/announcements (教师): 发布系统公告;
- GET /api/v1/admin/announcements: 获取公告列表。

5.2 外部接口

- 无强制依赖的外部系统接口, 系统完全独立运行;
- 判题沙箱通过本地进程调用 (ProcessBuilder) 执行编译器命令, 不依赖外部网络服务;
- 预留邮件服务接口 (SMTP), 用于发送注册验证、密码找回邮件, 可后期接入;
- 预留 OAuth2.0 统一身份认证接口, 便于后续与学校统一身份认证平台对接。

6 运行设计

6.1 运行控制

1. 系统启动时自动初始化数据库连接池、Redis 连接池、判题工作线程池;
2. 系统启动时从数据库加载所有启用的题目信息至缓存, 降低首次访问延迟;
3. 判题服务作为独立线程池运行, 持续监听 Redis 判题任务队列, 有任务时立即消费;
4. 判题服务设置最大并发数 (默认 10 个任务同时执行), 超出排队等待;
5. 每个判题任务设置超时时间, 超时后强制终止子进程并返回 TLE 状态;

6. 系统关闭时，完成当前正在执行的判题任务，拒绝新任务接收，等待队列中任务处理完毕后优雅退出；
7. 支持热更新功能，修改题目内容或测试用例后无需重启服务，缓存自动失效并重新加载。

6.2 控制方式

- 前端采用 Vue.js 框架，通过 Axios 发送异步 HTTP 请求与后端交互；
- 后端采用 Spring Boot 框架，Controller 层接收请求，Service 层处理业务逻辑，DAO 层操作数据库；
- 判题结果采用前端长轮询方式获取（每 1 秒轮询一次，最多轮询 30 秒），判题完成后返回结果，超时后提示用户稍后查看；
- 系统公告采用 WebSocket 推送机制，实时通知在线用户新公告发布；
- 监控数据采用定时器定期采集（每 10 秒采集一次），通过 WebSocket 推送到监控大屏。

6.3 故障处理

1. 数据库连接异常：自动重试 3 次，每次间隔 1 秒，重试失败后返回统一错误响应，记录 ERROR 级别日志，触发告警通知；
2. Redis 连接异常：降级处理，判题任务直接同步执行，不经过队列，确保核心功能可用；
3. 编译器未安装或不可用：返回系统错误提示，记录详细错误日志，通知运维人员处理；
4. 用户代码导致沙箱崩溃：沙箱超时自动回收，判题服务记录异常并返回 RE 状态，不影响整体服务；
5. 判题任务积压超过阈值（队列长度 > 1000）：触发告警通知运维人员扩容；
6. 服务器资源（CPU/内存）占用超过 90

7 安全设计

7.1 身份认证与授权

- 采用 JWT（JSON Web Token）进行用户身份认证，Token 有效期为 2 小时，过期后需重新登录；
- JWT Token 使用 HMAC-SHA256 算法签名，密钥存储在服务端环境变量中，确保 Token 不可伪造；
- Token 中包含用户 ID、用户名、角色类型等基础信息，不包含敏感数据（如密码）；
- 所有需要登录的接口均需在请求头中携带 Authorization: Bearer <token>;

- 实现基于角色的访问控制（RBAC），通过拦截器/过滤器对所有请求进行权限校验；
- 学生只能访问个人数据（个人信息、提交记录、统计信息），教师可以访问全部数据；
- 接口层实现水平越权防范，用户只能操作本人资源，通过 URL 中的用户 ID 与 Token 中的用户 ID 进行比对校验。

7.2 数据安全

- 用户密码采用 BCrypt 算法加密存储，加盐强度设为 10 轮，绝不存储明文密码；
- 数据库连接配置中启用 SSL 加密传输；
- 生产环境强制启用 HTTPS 协议，使用 TLS 1.2 及以上版本，防止中间人攻击；
- 敏感操作（登录、密码修改、删除数据、导入题目）记录详细操作日志，便于审计追溯；
- 用户提交的代码在存储前进行敏感信息脱敏（如包含密码、密钥等模式识别并替换），防止代码泄露个人信息。

7.3 输入安全

- 所有用户输入（题目描述、代码提交、帖子内容、评论）进行 XSS 过滤，防止跨站脚本攻击；
- 所有数据库操作使用 MyBatis 参数化查询，防止 SQL 注入攻击；
- 文件上传（批量导入题目）限制文件类型为.txt 或.json，对上传文件内容进行格式校验；
- 代码提交内容进行长度限制（不超过 65535 字符），防止超大代码拖垮判题服务；
- 请求参数进行严格的类型校验和范围校验，防止非法参数导致系统异常；
- 使用 API 限流策略（令牌桶算法），对单 IP/单用户的请求频率进行限制（每分钟不超过 60 次）。

7.4 沙箱安全

- 判题沙箱采用 Linux Namespace + Cgroup 技术实现进程隔离、资源限制；
- 禁止用户代码访问网络、操作系统文件、系统进程等敏感资源；
- 使用独立的临时目录存放用户代码和执行文件，执行完毕后立即清理；
- 设置用户代码执行用户为 nobody（最低权限用户），无法读写系统文件；
- 设置 CPU 时间限制（默认 1 秒）、内存限制（默认 256MB）、进程数限制（默认 1 个）；
- 沙箱执行环境与主机操作系统隔离，即使代码存在漏洞也无法影响主机安全。

7.5 日志与审计

- 系统日志按级别（ERROR、WARN、INFO、DEBUG）分类记录；
- 关键操作日志包含操作人、操作时间、操作内容、IP 地址、User-Agent 等信息；
- 审计日志保留至少 180 天，用于安全事故追溯和合规审计；
- 日志文件按日期滚动归档，每日切割，保留最近 30 天日志文件；
- 提供日志查看接口（仅限管理员），支持按时间、用户、操作类型筛选查看。

8 系统维护设计

8.1 系统监控

- 提供管理员监控大屏，展示以下关键指标：
 - 实时在线用户数；
 - 判题任务队列长度；
 - 服务器 CPU 使用率、内存使用率、磁盘使用率；
 - 今日提交总数、今日新增用户数；
 - 各判题状态占比（AC/WA/TLE 等）统计图表；
 - 最近 10 条判题日志。
- 监控数据每 10 秒刷新一次，通过 WebSocket 推送到前端；
- 系统健康检查接口（/actuator/health），供外部监控系统定时探测；
- 异常情况（服务不可用、资源使用率超阈值）自动发送告警邮件（预留 SMTP 接口）。

8.2 系统备份与恢复

- 数据库每日凌晨 2:00 自动全量备份，使用 mysqldump 工具，备份文件压缩存储；
- 备份文件保留最近 30 天，超过 30 天自动删除；
- 系统核心配置文件（application.yml、日志配置）纳入版本控制管理；
- 提供数据恢复脚本，支持将备份文件快速恢复到指定时间点；
- 判题临时文件目录每日定时清理（凌晨 3:00），释放磁盘空间。

8.3 系统扩展性

- 判题服务支持水平扩展，多实例部署时共享 Redis 任务队列，实现负载分摊；
- 编程语言支持可扩展，通过配置文件新增语言的编译命令和执行命令；
- 题库支持在线新增、修改、删除，无需重新部署服务；
- 支持通过配置文件调整判题超时时间、内存限制、并发数等参数，无需重启服务；
- 数据库读写分离预留接口，便于后续扩展从库应对高并发查询场景。

9 附录

9.1 附录 A：判题状态码定义

状态码	英文标识	说明
0	PENDING	待判题，任务已进入队列
1	JUDGING	判题中，正在执行评测
2	AC	Accepted，答案正确，通过全部测试用例
3	WA	Wrong Answer，答案错误
4	TLE	Time Limit Exceeded，运行超时
5	MLE	Memory Limit Exceeded，内存超限
6	RE	Runtime Error，运行时错误
7	CE	Compile Error，编译错误
8	PE	Presentation Error，输出格式错误
9	SE	System Error，系统错误（沙箱异常）

9.2 附录 B：系统错误码定义

错误码	说明
200	请求成功
400	请求参数错误
401	未认证（Token 缺失或无效）
403	权限不足（角色无权访问）
404	资源不存在
409	资源冲突（用户名/邮箱已存在等）
429	请求过于频繁（触发限流）
500	服务器内部错误
503	服务暂时不可用（判题服务繁忙）

9.3 附录 C：技术选型清单

技术栈	版本	用途
Spring Boot	2.7.x	后端基础框架
MyBatis-Plus	3.5.x	ORM 数据库操作框架
JWT	0.9.x	身份认证 Token 生成与验证
MySQL	8.0	关系型数据库
Redis	6.2	缓存与判题任务队列
Vue.js	3.x	前端基础框架
Element Plus	2.x	前端 UI 组件库
Monaco Editor	0.34.x	在线代码编辑器（VS Code 内核）
Nginx	1.22	Web 服务器/反向代理
Docker	20.10	可选部署容器化方案

10 接口设计

10.1 接口架构与设计原则

本系统采用 B/S 架构和前后端分离模式。面向实训项目规模，后端优先采用**模块化单体**，将六个业务模块部署在同一 Spring Boot 应用中，通过清晰的应用服务接口隔离职责；文档生成属于 CPU、内存和文件 I/O 密集型任务，采用独立工作进程异步执行。该方案兼顾小团队开发效率、事务一致性与后续拆分能力，不在当前阶段引入微服务治理成本。

技术基线如下：

- 展示层：Vue 3、TypeScript、Vite 和 Element Plus 构建单页应用；富文本编辑器采用基于 ProseMirror 内核的成熟组件，统一维护章节、段落、图片、表格和引用锚点；
- 接入层：Nginx 提供 HTTPS 终止、静态资源发布、反向代理、下载限速和统一访问日志；
- 应用层：Spring Boot 提供 RESTful API，Spring Security 完成身份认证与角色授权，业务代码按认证、学院、模板、写作、预览导出、批阅六个模块组织；
- 数据层：MySQL 8.0 保存强一致业务数据，Redis 保存短期会话状态、自动保存防抖键、编辑锁和异步任务状态；
- 文件层：对象存储保存论文图片、生成中的临时文件和可下载文件；开发环境可采用受控本地目录，生产环境建议使用 MinIO 等私有对象存储；
- 文档生成层：以“模板版本快照 + 论文结构化内容 + 媒体资源 + 参考文献”为统一输入，使用 docx4j 或 Apache POI 生成 DOCX，再由 LibreOffice Headless 转换为 PDF；网页预览、DOCX 和 PDF 共享同一份规范化文档模型。

接口设计遵循以下原则：

1. **边界稳定**：跨模块仅传递业务标识、状态和必要的只读数据，不允许一个模块直接修改另一个模块拥有的数据表；

2. **同步与异步分离**：登录、查询、保存、状态流转采用同步接口；预览重建、DOCX/PDF 生成、过期文件清理采用异步任务；
3. **版本可追溯**：论文始终绑定创建时的模板版本，提交、批阅和导出均携带论文内容版本，避免模板更新或并发保存改变历史结果；
4. **统一鉴权**：所有业务接口在接入层之后仍由后端校验角色和资源归属，前端隐藏按钮不能替代权限控制；
5. **失败可恢复**：会改变状态的接口具备幂等控制，异步任务可重试且保留失败原因，跨存储操作具备补偿和清理机制。

10.2 用户界面接口

系统仅面向 PC 端浏览器提供 Web 界面，不提供专用硬件接口和移动端原生接口。界面层以角色工作台为入口，并通过统一的导航、表单校验、确认弹窗和 Toast 反馈保持交互一致。

10.2.1 管理员界面

管理员端包含学院管理、模板列表、模板新增/编辑、模板详情和版本信息等页面。模板编辑页面按基本信息、封面字段、章节结构、排版参数四个区域组织。删除学院、删除模板、停用模板等操作必须显示影响范围并进行二次确认；存在被引用数据时，界面应阻止物理删除并提示采用停用方式。

10.2.2 学生界面

学生端包含论文工作台、模板选择、分章节编辑、参考文献管理、全文预览、导出任务和批阅结果等页面。编辑器持续显示“已保存、保存中、保存失败、离线”四类状态；自动保存失败时不得清空本地编辑内容。论文提交后，编辑控件切换为只读状态，并清晰展示当前状态、提交教师 and 最近一次批阅结果。

10.2.3 教师界面

教师端包含待批阅列表、论文只读预览、批注面板、整体评语、评分和历史记录。教师批注必须绑定到某次不可变的提交版本；当学生重新提交时，历史批注保持可查，新旧版本不得混写。

10.3 外部软件接口

系统无教务、查重、AI 写作等第三方业务系统接口。对外软件接口主要包括浏览器访问接口、文件上传下载接口以及基础设施适配接口。

文件上传接口使用 `multipart/form-data`，支持 JPG、PNG、GIF 和经过安全处理的 SVG，单文件不超过 5MB。服务端同时校验扩展名、MIME 类型和文件特征，不以客户端声明作为唯一依据。下载接口不暴露对象存储物理路径，而是由应用服务校验权限后返回短时下载凭证或通过 Nginx 内部转发。

表 5: 主要外部接口分组

接口分组	调用方/提供方	主要职责	关键约束
认证与账户	Web 前端/应用服务	注册、登录、刷新登录状态、退出	密码不回传; 限流; 返回角色与最小必要资料
学院与模板	管理员端/应用服务	学院维护、模板筛选、配置、版本与上下架	仅管理员; 模板保存生成新版本; 引用中的版本不可破坏
论文写作	学生端/应用服务	创建论文、加载章节、保存内容、管理引用	仅论文所有者; 内容版本校验; 提交状态禁止写入
媒体与文献	学生端/文件及应用服务	图片上传、媒体引用、文献录入和排序	文件类型及大小校验; 资源归属校验; 引用序号统一重算
预览与导出	学生端/文档生成服务	创建预览、发起导出、查询进度、下载结果	基于已保存版本; 任务幂等; 下载地址短时有效
提交与批阅	学生端、教师端/应用服务	提交锁定、批注、评分、退回、通过、查看历史	仅课程论文; 教师归属校验; 状态机与事务控制

10.4 内部模块接口

六个业务模块及平台支撑组件之间的协作关系如下。

表 6: 内部模块协作关系

调用模块	被调用模块	交互内容	约束
全部业务模块	认证与权限模块	当前用户、角色、资源访问判定	每次敏感操作重新鉴权, 不信任前端角色参数
模板管理模块	学院管理模块	校验学院存在与可用状态	模板必须归属有效学院, 删除学院前检查引用
在线写作模块	模板管理模块	获取启用模板及指定版本快照	创建论文后固定版本, 不跟随模板后续修改
在线写作模块	预览导出模块	提交论文版本、章节、资源和导出范围	只读取已保存内容, 不直接修改论文
批阅模块	在线写作模块	读取提交快照并驱动论文状态变更	状态变更在事务中完成, 批注绑定提交版本
预览导出模块	文件存储适配器	读取图片并写入生成文件	使用逻辑资源标识, 不在业务层拼接物理路径
全部业务模块	审计与监控组件	记录操作事件、异常和性能指标	审计写入失败不得泄露业务数据, 关键操作需告警

10.5 异步任务接口

文档生成任务通过 Redis 任务队列或可靠任务表投递, 任务内容仅保存任务标识、论文标识、论文内容版本、模板版本、导出格式、导出范围和发起人标识, 不在消息体中复制整篇论文。工作进程领取任务后从 MySQL 和对象存储读取一致性快照, 生成文件后回写任务状态与文件标识。

导出任务状态统一为“等待、处理中、成功、失败、已过期”。同一用户对同一论文版本、同一格式和同一范围的重复请求复用未过期结果; 工作进程异常退出后, 超时的处理中任务可被重新领取。任务至少投递一次, 因此生成过程必须以任务标识保证幂等。

10.6 通用接口约定

1. 接口根路径统一使用版本前缀 `/api/v1`, 传输协议为 HTTPS, 字符编码为 UTF-8, 普通请求和响应使用 JSON;

2. 登录成功后使用短时访问令牌访问接口，刷新令牌仅用于换取新访问令牌；退出登录或账号禁用后，相关令牌进入失效状态；
3. 响应统一包含业务结果、可读提示、追踪标识 `traceId` 和服务器时间；失败响应不返回堆栈、SQL 或物理文件路径；
4. 列表接口统一支持页码、每页数量、排序和白名单筛选条件，每页数量设置上限，防止一次读取过多数据；
5. 保存接口携带内容版本号，服务端采用乐观锁判断并发冲突；状态变更接口携带幂等键，重复调用返回同一业务结果；
6. HTTP 状态码表达传输层结果，业务错误码表达认证、参数、权限、状态冲突、存储、生成和系统异常等类别。

11 数据结构设计

11.1 数据架构原则

数据结构围绕“模板版本化、论文分章节、提交快照不可变、批阅可追溯、文件与业务记录分离”设计。MySQL 作为事实数据源，Redis 只保存可重建的短期数据，对象存储只保存二进制资源和生成文件。任何缓存或文件缺失均不得导致论文核心文本、模板版本和批阅结论丢失。

11.2 逻辑结构设计

11.2.1 组织与身份数据

- **用户：**保存用户名、密码摘要、角色、所属学院、账号状态和审计时间。用户名唯一；角色限定为管理员、学生、教师；
- **学院：**保存学院名称、描述和有效状态，为模板分类和用户归属提供基础数据；
- **教师分配关系：**保存课程论文与授课教师的对应关系，用于教师资源权限判定，不允许仅凭前端传入教师标识建立授权。

11.2.2 模板数据

- **论文模板：**保存模板名称、类型、学院、启停状态、当前版本号和说明，表示可管理的模板主记录；
- **模板版本：**保存某一版本的完整快照，包括封面字段、章节结构、排版参数和固定文本。配置采用带模式版本号的 JSON 存储，保存后不可原位覆盖；
- **模板资源：**保存模板引用的校徽、声明页背景等资源标识，不在 JSON 中保存二进制内容。

11.2.3 写作与引用数据

- **论文**：保存论文标题、学生、论文类型、绑定的模板版本、当前状态、内容版本、教师和时间信息；
- **论文章节**：按模板章节顺序保存章节类型、标题、层级、可编辑属性和富文本内容。内容以净化后的 HTML 或结构化 JSON 保存，并为段落、表格、图片等块分配稳定锚点；
- **参考文献**：保存文献类型、作者、标题、来源、年份、卷期和页码等结构化字段，并保存论文内排序号；
- **正文引用**：关联论文、章节锚点和参考文献，导出时根据文献顺序统一生成编号；
- **媒体资源**：保存原文件名、对象存储键、内容类型、大小、摘要值、上传者 and 引用状态，二进制数据不进入 MySQL。

11.2.4 导出与批阅数据

- **导出任务**：保存论文内容版本、模板版本、格式、范围、任务状态、失败原因、生成文件和过期时间；
- **提交版本**：学生提交时固化论文标题、章节内容、引用关系、资源清单和模板版本，形成不可变快照；
- **批阅任务**：关联提交版本、学生和教师，记录待批阅、已通过、已退回等状态；
- **批注**：关联提交版本和稳定内容锚点，保存批注文本、创建人和创建时间；
- **评阅结果**：保存整体评语、分数、等级、结论和处理时间；等级由分数区间校验；
- **操作审计**：记录主体、动作、目标类型、目标标识、结果、IP、追踪标识和时间，不保存密码、令牌和论文全文。

11.3 核心实体关系

1. 一个学院可关联多个模板和多个用户；学院存在有效模板时不得直接物理删除；
2. 一个模板包含多个不可变模板版本，模板主记录指向当前版本；一篇论文只绑定一个模板版本；
3. 一个学生可创建多篇论文，一篇论文包含多个有序章节、参考文献、引用和媒体资源；
4. 一篇课程论文可以产生多个提交版本，每次提交版本对应一次批阅任务；批注和评阅结果均绑定具体提交版本；
5. 一个提交版本只能来源于一个已保存论文内容版本，历史提交内容不随学生后续修改而变化；
6. 一个导出任务对应一个确定的论文内容版本和模板版本，生成文件可在有效期内被多次下载。

11.4 状态模型与一致性约束

11.4.1 模板状态

模板状态为“已启用”或“已停用”。只有已启用模板可用于新建论文；停用、删除模板不影响已创建论文。模板编辑采用新增版本方式，旧版本不可覆盖，并通过模板版本号和配置模式版本号共同保证可解释性。

11.4.2 论文状态

论文状态按以下路径流转：

- 正常完成路径：草稿 → 已提交 → 已批阅；
- 退回修改路径：草稿 → 已提交 → 已退回 → 已提交。

只有草稿和已退回状态允许学生编辑；提交操作在同一事务内完成内容版本校验、提交快照创建、论文锁定和批阅任务创建。教师通过或退回时必须校验当前批阅任务仍处于待处理状态，防止重复处理。

11.4.3 并发与版本约束

论文和模板主记录设置乐观锁版本。学生保存时携带上次读取的内容版本，版本不一致则返回冲突并保留客户端草稿，由用户选择刷新或复制未保存内容。自动保存与手动保存使用相同的保存通道，按论文标识串行化短时间内的写请求，避免乱序覆盖。

11.5 物理结构设计

表 7：数据存储分工

存储组件	数据范围	设计要求
MySQL 8.0	用户、学院、模板及版本、论文及章节、文献、提交与批阅、任务与审计	InnoDB 事务；外键或等价完整性校验；业务唯一索引；时间字段统一；关键查询建立组合索引
Redis	登录失效标识、自动保存防抖键、编辑短锁、导出任务进度和热点模板摘要	设置过期时间；不保存唯一副本；键包含环境和业务前缀；故障时允许降级到数据库
对象存储	图片、模板资源、DOCX/PDF 成品和临时中间文件	私有桶；随机对象键；元数据入库；临时文件和过期导出按策略清理

关系表使用统一主键、创建时间、更新时间和必要的逻辑删除标识。模板版本、提交版本、评阅结果和审计记录属于历史证据数据，不执行普通业务删除。大文本章节与高频列表字段分离，列表页不加载论文全文。JSON 配置必须通过服务端模式校验后写入，禁止将无法解释的任意字段直接落库。

11.6 索引与查询策略

- 用户名、学院名称建立唯一索引；模板按学院、类型、启用状态和更新时间建立组合索引；
- 论文按学生、状态和更新时间建立组合索引；待批阅任务按教师、状态和提交时间建立组合索引；
- 章节按论文和顺序号唯一定位；参考文献按论文和排序号唯一定位；
- 导出任务按发起人、论文、内容版本、格式和状态查询；审计日志按时间、主体和目标标识检索；
- 论文预览所需章节、文献和资源采用批量读取，避免逐章节、逐资源产生大量数据库往返。

11.7 数据结构与模块关系

- 认证与权限模块拥有用户数据，对其他模块只提供身份和授权判定；
- 学院管理模块拥有学院数据，模板管理模块通过学院查询接口引用；
- 模板管理模块拥有模板、模板版本和模板资源，在线写作模块只读取指定版本快照；
- 在线写作模块拥有论文、章节、文献、引用和媒体元数据，预览导出模块只读取一致性快照；
- 批阅模块拥有提交版本、批阅任务、批注和评阅结果，并通过论文状态接口驱动锁定或解锁；
- 平台支撑组件拥有导出任务、审计和监控数据，不反向修改业务内容。

12 运行设计

12.1 部署与进程结构

系统在逻辑上分层，在物理部署上由五类运行单元组成：

1. **Web 前端与 Nginx**：发布静态资源、代理 API、限制上传大小、转发受控下载；
2. **应用服务**：运行六个业务模块，承担认证、事务、权限、状态流转和任务投递；
3. **文档生成工作进程**：消费导出任务，装配规范化文档模型，生成 DOCX 并转换 PDF；
4. **数据服务**：MySQL 提供持久化，Redis 提供短期状态与队列；
5. **文件服务**：对象存储保存上传资源和生成文件。

开发及小规模验收环境可部署为单机多进程；生产环境建议将应用服务、文档生成进程、数据库和对象存储分离。应用服务应保持无状态，可部署多个实例；生成进程按 CPU 和内存容量独立扩缩，不与在线保存接口争用同一工作线程池。

表 8: 主要业务场景的模块组合

业务场景	参与模块	协作结果
模板发布	认证权限、学院管理、模板管理、审计组件	校验学院和管理员权限,生成模板新版本并切换启用状态
创建与写作	认证权限、模板管理、在线写作、文件存储	绑定模板版本,创建章节,保存正文、文献和图片
预览与导出	在线写作、预览导出、文档生成进程、对象存储	读取已保存快照,生成预览或 DOCX/PDF 并提供受控下载
提交与批阅	认证权限、在线写作、批阅、审计组件	固化提交版本并锁定,教师批注评分,按结论解锁或完成
运维恢复	监控审计、数据库、Redis、对象存储	定位失败任务、恢复服务、重放幂等任务并验证数据完整性

12.2 运行模块组合

12.3 关键运行流程

12.3.1 论文自动保存流程

学生编辑产生变更后,前端先更新本地草稿,并在空闲窗口内合并变更;每 30 秒或用户手动保存时,将论文标识、内容版本和变化后的章节内容提交后端。后端依次完成身份校验、资源归属校验、论文状态校验、内容净化、字数与资源限制校验、乐观锁更新和保存审计。保存成功返回新内容版本;网络失败时前端保留本地草稿并提示重试。

12.3.2 预览与导出流程

用户发起预览或导出时,系统只使用最近一次保存的内容版本。应用服务建立导出任务并立即返回任务标识,文档生成进程异步执行以下步骤:

1. 读取论文、模板版本、章节、参考文献和资源清单,验证快照完整性;
2. 将模板配置和论文内容合并为规范化文档模型,统一计算章节编号、目录、引用编号和分页属性;
3. 预览适配器生成分页 HTML; Word 适配器生成 DOCX; PDF 适配器由同一 DOCX 转换成 PDF;
4. 校验生成文件存在、大小非零、页数可读取后写入对象存储;
5. 更新任务状态并记录生成耗时、文件摘要和失败原因。

前端通过任务查询接口获取进度,不保持长连接占用应用线程。任务失败允许用户重试,但已成功且未过期的相同任务直接复用。

12.3.3 提交与批阅流程

学生确认提交后,后端在事务内校验论文类型、教师归属、必填章节和最新内容版本,创建不可变提交快照,将论文状态改为已提交并生成待批阅任务。教师打开的始终是该提交快照,不是学

生工作副本。教师保存批注可多次进行，最终通过或退回时一次性校验分数、等级和状态；通过后论文进入已批阅，退回后进入已退回并允许学生继续编辑。

12.4 运行控制

1. **认证控制**：Nginx 只负责接入，应用服务对每个接口执行令牌、角色和资源归属校验；
2. **事务控制**：模板版本发布、论文提交、教师结论等多记录变更在单个数据库事务内完成；
3. **并发控制**：模板和论文使用乐观锁；导出任务使用任务租约；同一批阅任务只允许一个终态写入；
4. **幂等控制**：提交、通过、退回和导出请求携带幂等键，重复请求不得产生多份业务记录；
5. **超时控制**：数据库、Redis、对象存储和文档转换均设置连接及执行超时，超时后释放资源并记录追踪标识；
6. **限流控制**：登录、图片上传和导出接口按用户及 IP 限流；导出任务按用户设置并发上限；
7. **降级控制**：Redis 不可用时登录和数据库业务可继续运行，自动保存防抖和热点缓存退化为数据库方案；文档服务不可用时编辑与保存仍可使用。

12.5 性能与容量设计

性能目标与需求规格保持一致：

- 标准网络环境下普通页面首屏加载不超过 2 秒，普通查询接口的服务端 P95 响应时间控制在 1 秒以内；
- 论文保存操作服务端处理时间不超过 1 秒，自动保存不得阻塞编辑器输入；
- 网页预览在 3 秒内可用；万字以内论文的 DOCX 或 PDF 导出目标不超过 10 秒，超出时仍以异步任务方式完成并展示状态；
- 单篇论文字数不超过 50000 字，图片不超过 50 张且单张不超过 5MB，参考文献不超过 200 条；
- 应用服务线程池与文档生成线程池隔离。文档生成并发数依据单任务峰值内存和 CPU 核数配置，不以无限排队换取表面成功率；
- 列表接口默认分页，论文正文按需加载；模板摘要可缓存，论文正文、提交快照和评阅结果不依赖缓存作为唯一数据源。

12.6 定时任务

- 每 5 分钟扫描超时的导出任务，将失去租约的任务恢复为可重试状态；
- 每日清理超过有效期且无业务引用的导出文件、上传临时文件和失败中间文件；
- 每日校验数据库记录与对象存储对象的引用一致性，输出孤儿文件和缺失文件清单；
- 每日执行数据库备份并校验备份结果，定期进行恢复演练；
- 每月归档过期访问日志与运行指标，审计日志按安全策略保留。

13 出错处理设计

13.1 处理原则与异常分类

系统按照“对用户可理解、对运维可定位、对业务可恢复”的原则处理异常。异常分为参数校验、认证授权、资源不存在、业务状态冲突、并发冲突、文件处理、基础设施、文档生成和未知系统异常九类。每次失败均生成追踪标识，用户提示与后台日志通过该标识关联。

13.2 出错输出信息

1. 用户侧只显示可执行的提示，例如“内容版本已变化，请刷新后重试”“图片超过 5MB”“论文已提交，当前不可编辑”“导出失败，可重新发起”；
2. 接口响应包含稳定错误码、简短消息、必要的字段级校验信息和 `traceId`，不包含堆栈、SQL、服务器目录、对象存储键和安全配置；
3. 后台日志记录异常类型、业务标识、调用链、耗时和受控上下文。论文正文、密码、令牌和上传文件内容不得写入日志；
4. 异步任务失败记录失败阶段、可重试性、重试次数和最后异常摘要，前端可展示任务失败状态但不展示内部异常详情。

13.3 主要异常及处理对策

13.4 重试、补偿与回滚

1. 只对查询、幂等写入和明确标记可重试的异步任务自动重试，采用递增退避并设置最大次数；认证失败、参数错误和业务状态冲突不自动重试；
2. 数据库事务失败全部回滚。数据库记录与对象存储无法组成分布式事务时，先上传到临时区，再提交业务记录，最后转为正式对象；任一步失败均由清理任务补偿；
3. 导出任务生成新文件成功并校验后才更新文件引用，失败时保留上一份成功文件，不向用户提供半成品；

表 9: 异常处理策略

异常场景	用户侧处理	服务端处理	恢复与告警
登录失败或越权	提示凭据错误、账号禁用或权限不足	统一拒绝并记录安全事件；不区分用户名是否存在	短时间多次失败触发限流和告警
保存版本冲突	保留本地草稿，提示刷新或复制内容后处理	拒绝覆盖，返回当前版本摘要	统计冲突率，检查多端同时编辑情况
网络中断	显示离线状态，保留本地编辑内容	未收到完整请求不写库；幂等请求可重试	网络恢复后由用户或客户端重试
图片上传失败	明确提示格式、大小或网络原因	删除未完成临时对象，保持论文内容不变	重试失败或安全检测异常时告警
数据库或 Redis 异常	提示暂时不可用，编辑内容留在本地	数据库事务回滚；Redis 功能降级，不写入不一致结果	熔断、健康检查、连接恢复后验证
文档生成失败	保留论文，显示失败任务并允许重试	标记失败阶段，清理中间文件，不覆盖旧成功文件	达到重试上限后人工介入并告警
对象存储不可用	暂停上传和下载，写文本本仍可保存	快速失败，不生成无文件的成功记录	恢复后重试任务并执行引用一致性检查

4. 论文提交失败不得产生“已锁定但无提交版本”或“有批阅任务但仍可编辑”的中间状态；启动时和定时任务均检查此类不变量；
5. 教师最终结论写入失败时，批注草稿可以保留，但论文状态和评阅终态必须保持未变，允许教师重新提交结论。

13.5 日志、监控与告警

应用日志采用结构化格式，并携带请求追踪标识、用户匿名标识、模块、接口、耗时和结果。监控至少覆盖接口错误率与 P95 耗时、数据库连接池、Redis 可用性、导出队列长度、最老任务等待时间、文档生成成功率、对象存储容量和磁盘临时目录使用率。

当普通接口连续 5 分钟错误率超过 1%、保存接口 P95 超过 1 秒、最老导出任务等待超过 2 分钟、文档生成连续失败、存储使用率超过 80% 或数据库连接池持续超过 80% 时触发告警。告警应包含环境、时间、模块、指标和值，不包含论文正文和个人敏感信息。

14 安全保密设计

14.1 安全目标与信任边界

系统保护的核心资产包括账号凭据、用户个人信息、论文内容、模板配置、提交快照、教师批注与评分、上传图片和导出文件。浏览器、互联网请求和用户上传内容均视为不可信；Nginx 之后的应用服务仍需进行完整校验；数据库、Redis 和对象存储仅允许内网访问。

14.2 身份认证与权限控制

1. 密码采用 BCrypt 或 Argon2 等带盐单向摘要算法保存，禁止明文、可逆加密和日志记录；

2. 登录采用短时访问令牌和受控刷新机制，令牌包含最小必要身份信息；账号禁用、退出和密码变更后使相关令牌失效；
3. 采用 RBAC 与资源归属双重授权：管理员仅管理学院和模板；学生仅管理本人论文；教师仅查看并批阅分配给本人的课程论文；
4. 后端根据当前登录主体确定用户标识，不接受客户端通过修改学生、教师或管理员标识绕过授权；
5. 论文提交、模板删除、模板停用、评分结论等敏感操作要求二次确认，并记录审计事件。

14.3 接口与会话安全

- 对外通信强制 HTTPS，建议 TLS 1.2 及以上；HTTP 自动重定向到 HTTPS；
- CORS 仅允许受控前端域名；根据令牌存放方式配置 CSRF 防护，并设置 CSP、X-Content-Type-Options 等安全响应头；
- 登录、注册、上传和导出接口实施用户及 IP 维度限流；异常请求不消耗无限线程、内存或临时磁盘；
- 所有查询采用参数化访问，排序字段和筛选字段使用白名单，防止 SQL 注入和任意字段访问；
- 服务端统一校验长度、枚举、数字范围、状态和业务归属，不能仅依赖前端表单校验。

14.4 富文本与文件安全

1. 富文本内容使用标签、属性和协议白名单净化，移除脚本、事件属性、外部执行内容和危险 URL，预防存储型 XSS；
2. 图片上传同时校验扩展名、MIME 类型、文件特征、大小和数量；文件名只作为展示信息，存储键由系统随机生成；
3. SVG 在入库前删除脚本、外链、事件属性和嵌入对象，无法安全净化时转换为 PNG 或拒绝上传；
4. 上传对象放入私有存储区域，禁止直接执行；下载时设置正确的内容类型和 Content-Disposition；
5. DOCX/PDF 生成在低权限工作目录中完成，限制单任务 CPU、内存、执行时间和临时磁盘，任务结束后清理临时文件；
6. 文档生成引擎不得加载用户提供的宏、外部链接资源或任意本地路径，模板中所有资源必须来自自己登记的对象标识。

14.5 数据保护与保密

- 数据库账号遵循最小权限，应用、备份和运维使用不同账号；Redis 和对象存储启用认证并限制网络来源；
- 生产密钥、数据库密码和对象存储凭据通过环境密钥或专用配置中心注入，不写入源代码和版本库；
- 备份文件、导出文件和传输链路按环境能力加密；下载文件使用短时授权，过期后自动失效；
- 页面和接口仅返回完成当前业务所需的字段；教师不可读取未提交论文，管理员不可读取学生正文；
- 论文批阅历史属于业务证据数据，按论文生命周期保留；临时导出文件按有效期清理，用户注销或数据清理按学校制度执行。

14.6 审计与安全事件

模板新增、版本发布、启停和删除，论文提交、退回、通过和评分，账号禁用，越权访问，连续登录失败，文件安全校验失败等操作必须进入审计日志。审计记录应防止普通业务用户修改，包含操作人、角色、目标、结果、时间、来源 IP 和追踪标识。

出现疑似泄露或恶意访问时，运维人员可按追踪标识冻结相关账号和令牌、暂停导出、保存证据日志、核查访问范围并恢复服务。安全事件处置过程不得通过删除业务数据掩盖问题。

15 维护设计

15.1 维护目标与总体策略

维护设计以“可定位、可替换、可回滚、可恢复”为目标。当前系统采用模块化单体而非微服务，六个业务模块拥有明确数据和服务边界；文档生成、文件存储、缓存等变化较快或资源特征明显的功能通过适配器隔离，使小团队能够在不改变核心业务流程的前提下升级技术组件。

15.2 模块与依赖维护

1. 业务模块只依赖公开的应用服务接口，不跨模块直接访问数据访问对象；公共代码限于认证上下文、错误模型、审计、时间和基础工具；
2. 文档生成采用“规范化文档模型 + 格式适配器”，新增导出格式或替换 DOCX/PDF 引擎时不修改写作和批阅模块；
3. 文件存储通过统一资源接口访问，开发环境本地存储和生产对象存储可按配置切换；
4. 模板 JSON 包含模式版本号，新增排版参数时提供向后兼容默认值和升级程序，历史模板版本必须仍可导出；
5. 数据库变更使用 Flyway 或同类迁移工具按版本执行，迁移脚本只追加不篡改，发布前在备份副本上验证。

15.3 配置与版本管理

开发、测试和生产环境分别维护配置，数据库地址、Redis 地址、对象存储、令牌有效期、上传限制、导出并发、文件有效期和告警阈值全部外置。敏感配置与普通配置分离，生产密钥不得出现在配置样例中。

前端、应用服务、文档生成进程和数据库模式均记录版本。导出文件元数据保存生成引擎版本、模板版本和论文内容版本，出现排版问题时可复现生成条件。API 采用主版本前缀；不兼容变更发布新版本并保留迁移窗口。

15.4 日志与监控维护

- 访问日志、应用日志、文档生成日志、审计日志分流保存，统一时间、环境、级别、模块和追踪标识；
- 访问及应用日志按天滚动，在线保留 30 天后归档或清理；审计日志至少保留 180 天，具体期限服从学校制度；
- 监控面板展示服务可用性、接口耗时、保存成功率、导出任务、数据库、Redis、对象存储和主机资源；
- 每周复核慢查询、重复异常和失败任务；对高频问题建立故障知识库，记录现象、影响、定位方法和恢复步骤；
- 日志清理策略必须先于磁盘占满，临时目录、导出目录和数据库日志分别设置容量阈值。

15.5 数据备份与恢复

1. MySQL 每日全量备份并持续保留二进制日志，目标恢复点 RPO 不超过 15 分钟；模板版本、提交版本、评阅结果和审计数据纳入核心备份；
2. 对象存储每日增量备份论文图片和模板资源；可重新生成且已过期的导出文件不作为最高优先级备份对象；
3. Redis 不承担唯一数据存储，故障后允许从数据库重建缓存和任务状态；
4. 备份文件异地或跨磁盘保存、加密并校验摘要；仅有备份文件不视为备份成功，至少每季度执行一次恢复演练；
5. 目标恢复时间 RTO 不超过 2 小时。恢复顺序为数据库、对象存储、应用服务、文档生成进程、缓存，恢复后执行数量、引用和抽样导出校验。

15.6 发布、回滚与兼容性维护

发布流程依次执行代码检查、单元测试、接口测试、模板兼容测试、典型论文导出回归、数据库迁移验证和安全扫描。构建产物应不可变并带版本号。生产发布前完成备份，优先采用双实例滚动或双槽切换，确认健康检查、保存和导出均正常后再结束观察期。

回滚时先回退应用和前端产物；数据库迁移优先采用向前兼容设计，避免依赖破坏性回滚。涉及文档引擎升级时保留上一版本工作进程和典型样例基线，一旦出现严重排版差异，可将新任务切回上一引擎。

15.7 例行维护计划

表 10: 例行维护项目

周期	维护内容	通过标准
每日	检查备份、告警、导出失败任务、磁盘与对象存储容量	备份成功；无未解释严重告警；积压任务已处置
每周	分析慢查询、错误趋势、账号异常和孤儿文件清单	关键问题有负责人、原因和完成期限
每月	安装经验证的依赖安全补丁，复核权限、日志容量和告警阈值	无高危未处置漏洞；权限符合最小化原则
每季度	执行备份恢复、故障切换和典型 DOCX/PDF 回归演练	满足 RPO/RTO；典型文档排版基线通过
每次发布	执行自动化测试、数据库迁移验证和回滚预案检查	发布清单签字确认，观察期无阻断问题

15.8 扩展与演进设计

- 新增论文类型时，优先扩展模板类型、章节配置和校验规则，不复制整套写作流程；
- 新增导出格式时，实现新的文档格式适配器，并复用规范化文档模型、资源解析和任务管理；
- 未来对接教务系统时，在组织与身份边界增加同步适配层，不让外部字段直接进入核心领域模型；
- 当导出量成为主要瓶颈时，可独立扩容文档生成工作进程；当模块确有独立发布和容量需求时，再基于现有接口边界拆分服务；
- 任何演进均应保持历史模板版本、提交版本和评阅记录可读取、可预览、可导出。